AI COMPLIANCE AUDIT UTILITY

Compact Administrator’s Guide

Purpose: scan a local repository for masked AI credential indicators and assess explicitly authorized internal AI service endpoints. The tool writes a JSON report and can send critical alerts to a configured security channel.

1. Fastest safe start

```
cd /path/to/authorized-repository
python ai_compliance_audit.py ai-staging.corp.example
```

The target-only command scans the current working directory, audits the supplied host using defaults, and writes ai_compliance_report.json in that directory. Run it from the repository you intend to scan; the default root is not the script’s folder.

Prerequisite	Behavior
Python	Python 3.11 or later.
Dependencies	On first run, missing httpx and rich are installed automatically through the active interpreter’s pip. The script does not upgrade/version-check packages already present.
Enterprise setup	Prefer an isolated virtual environment and an approved internal package mirror; no separate pip install command is required.

Common optional overrides

```
python ai_compliance_audit.py --root /srv/repos --target ai-staging.corp.example
python ai_compliance_audit.py --target-file ./authorized-targets.txt --report ./audit.json
```

The positional target and --target are equivalent. Use only one target input: positional target, --target, or --target-file. The target must be an authorized hostname or IP without scheme, port, or path.

2. Inputs, target files, and runtime limits

Option	Default	Meaning
target_arg / --target	None	One authorized host; positional form is shortest.
--target-file	None	One hostname, IP, or CIDR per line; mutually exclusive with single-target inputs.
--root	Current directory	Local filesystem tree.
--report	ai_compliance_report.json	JSON output path.
--concurrency	8	Per-target concurrency; 1–16.
--target-concurrency	4	Simultaneous target audits; 1–16.
--global-connection-limit	32	Absolute shared limit for TCP, HTTP, and webhook operations; 1–256.
--connect-timeout	2 sec	TCP connect timeout; 0.1–15 sec.
--execution-timeout	900 sec	Global asynchronous network/notification deadline; 1–86,400 sec.
--entropy-threshold	4.2	Shannon entropy bits/character; greater than 0 to 8.
--notify	Unset	Optional slack, teams, or discord; may be configured once in environment.

Target-file format and safety bounds

```
# Authorized internal scope
10.20.30.0/24
ai-staging.corp.example
192.168.40.17
```

- Blank lines and text after # are ignored; duplicate targets are removed.
- A CIDR may expand to at most 256 addresses; the whole input is capped at 1,024 unique targets.
- Network checks are concurrent, but the global semaphore bounds active connection operations across all target workers and webhook attempts.

The global timeout wraps the asynchronous network and notification phase. It retains completed target results, marks unfinished targets, and writes a partial report. The synchronous filesystem scan runs before that deadline; it is bounded by the file and line limits described below.

3. Filesystem secret and entropy scan

Control	Behavior
Traversal	Regular files only; symlinks are not followed. Skips .venv, venv, node_modules, vendor, __pycache__, .cache, dist, build, .next, .tox, and .pytest_cache.
Binary detection	Skips a file when a NUL byte is present in the first 8 KiB.
File budget	Stops at 250,000 scanned files; report records count and whether the cap was reached.
Line memory cap	Reads and searches at most 8,192 characters per logical line; drains the remainder in bounded reads. Counts truncated lines in the report.
Output safety	Findings are masked. Raw token text and local file contents are not exported.

Provider indicators

Provider	Direct prefix or labeled setting
OpenAI	sk-... / sk-proj-...; OPENAI_API_KEY, OPENAI_KEY
Anthropic	sk-ant-...; ANTHROPIC_API_KEY
Gemini	AIzaSy...; GEMINI_API_KEY, GOOGLE_API_KEY
Hugging Face	hf_...; HF_TOKEN, HUGGINGFACEHUB_API_TOKEN
Groq	gsk_...; GROQ_API_KEY
Cohere / Mistral / DeepSeek	COHERE_API_KEY; MISTRAL_API_KEY; DEEPSEEK_API_KEY and related labels
Together / Perplexity	tgp_v1_... / pplx-...; TOGETHER_API_KEY / PERPLEXITY_API_KEY
OpenAI-compatible hex	sk- followed by 32–64 hex characters; generic DeepSeek/self-hosted-compatible shape, not conclusive vendor attribution.

The entropy fallback examines 24–128-character token-like strings. The default threshold is 4.2 bits/character; entropy findings can be hashes or benign identifiers. Patterns are indicators, not credential-validity checks.

Known limitation: a secret after character 8,192 on a very long line is not examined. A scan of the current filesystem snapshot is not a Git-history, public-repository, or cloud-bucket audit.

4. Internal endpoint checks

Port	GET route(s)
11434	/api/tags
8000	/v1/models, /health
8080	/health, /v1/models
7860 / 8501	/
6333	/healthz, /
19530	TCP check only; no HTTP route
8888	/api/status, /

Only the fixed port list is checked. No credentials are sent. HTTP response bodies are not read/stored and redirects are not followed. TCP and HTTP checks are bounded by the global connection semaphore and per-operation timeouts.

Conditional malformed POST

On ports 8000 or 8080, GET /v1/models returning 401, 403, 404, or 405 triggers one POST to /v1/chat/completions with {"model":"test"}; no messages or generation settings are included.

Result	Meaning
POST 401 / 403	Authentication required on the inference route.
POST 400 / 422	Request reached application validation; auth status for a valid inference request is unconfirmed.
POST 2xx	Critical review signal and alert trigger, but not proof that a valid generation request would succeed.
GET 2xx on models/health	Review metadata exposure; not automatically classified as critical.
Redirect / 404 / other	Not followed / route absent / inconclusive; review with service owner.

A critical result is a signal to verify gateway and service authentication in staging. The tool does not submit a valid prompt, retrieve models, or attempt model theft.

5. Alerts, reports, and operator workflow

Optional Slack / Teams / Discord alerts

Configure AI_AUDIT_WEBHOOK_PROVIDER as slack, teams, or discord and AI_AUDIT_WEBHOOK_URL through a protected environment or CI secret store. Then the target-only command remains unchanged. --notify may override the provider. The URL must use HTTPS and is never placed in the report or terminal output.

Alerts are sent only for a critical malformed POST result. Payloads contain target, port, route, and status—not secret values or source snippets. Retries are bounded; a critical result with no delivered alert produces exit code 3.

Report and exit codes

• ai_compliance_report.json includes scan statistics, masked findings, per-target TCP/HTTP results, critical exposures, notification status, and interpretation notes.

Exit	Meaning
0	Completed without a critical alert-delivery failure.
2	Input, filesystem, target, or report-writing error.
3	Critical exposure found, but alert was not configured or not delivered.
4	Global asynchronous execution deadline reached; partial report written.

Recommended runbook

• Confirm authorization and choose the intended repository directory or --root.

• Run first against one staging hostname; inspect the terminal tables and JSON report.

• Revoke/rotate confirmed exposed credentials through their owners; remove source copies and review CI artifacts/history with dedicated tools.

• For network signals, review service and gateway auth with the owner, remediate, then rerun.

• For CI, retain the report as a restricted artifact and map exit codes 2–4 to the pipeline policy.

Keep in mind

The utility scans local files and a fixed internal port/route set; it does not search public code hosts or cloud storage. Provider formats evolve. Review findings in context, keep dependencies on an approved package source, and use synthetic fixtures when testing detections.